

Aula 2 (Módulo 11) — Eventos Principais do Sysmon em Detalhe

Para cada evento: o que significa, um exemplo de campo relevante, o que investigar, e uma lógica de detecção simples (o mesmo espírito da regra Suricata do Módulo 04 — vamos formalizar a sintaxe real de detecção, Sigma, no Módulo 21).

Event ID 1 — Process Creation

O que é: um novo processo foi criado — o evento mais usado de todo o Sysmon, já citado desde o Módulo 02.

Campos principais: `Image` (caminho do executável), `CommandLine`, `ParentImage`, `ParentCommandLine`, `Hashes` (MD5/SHA1/SHA256/IMPHASH do arquivo, calculados automaticamente), `User`.

O que investigar: a árvore pai/filho faz sentido? A command line tem flags suspeitas? O hash é conhecido (Módulo 06, `hash-checker`)?

Lógica de detecção (exemplo):

```
SE ParentImage termina com "winword.exe" OU "excel.exe" OU "outlook.exe"
E Image termina com "powershell.exe" OU "cmd.exe"
ENTÃO alertar (Severidade: Alta)
```

Event ID 3 — Network Connection

O que é: um processo estabeleceu uma conexão de rede — TCP ou UDP, com IP/porta de origem e destino.

Campos principais: `Image` (qual processo conectou), `DestinationIp`, `DestinationPort`, `Initiated` (true = essa máquina iniciou a conexão, lembrando do Módulo 00, Aula 3).

O que investigar: o processo **deveria** fazer conexões de rede? O IP de destino é conhecido/confiável? A porta é atípica para aquele processo?

Lógica de detecção (exemplo):

```
SE Image termina com "powershell.exe"
E DestinationPort NÃO está em (80, 443)
E Initiated = true
ENTÃO alertar (Severidade: Média) — PowerShell conectando em porta
                                     incomum merece atenção
```

Event ID 7 — Image Loaded

O que é: um processo carregou uma DLL (biblioteca de código compartilhado). A maioria dos processos carrega dezenas de DLLs normais o tempo todo — **este é um dos eventos de maior volume**, por isso a configuração (Aula 1) geralmente restringe bastante o que é registrado aqui.

Campos principais: `Image` (processo), `ImageLoaded` (a DLL), `Signed` / `Signature` (a DLL é assinada digitalmente por um fabricante confiável?).

O que investigar: uma DLL **não assinada**, carregada de uma pasta incomum (`%TEMP%`), por um processo sensível, é um padrão associado a técnicas de **DLL injection/sideload**ing — código malicioso rodando "dentro" de um processo legítimo para se esconder melhor.

Lógica de detecção (exemplo):

```
SE ImageLoaded está em pasta %TEMP% ou %APPDATA%
E Signed = false
ENTÃO alertar (Severidade: Alta)
```

Event ID 11 — File Create

O que é: um arquivo foi criado ou sobrescrito.

Campos principais: `Image` (processo que criou), `TargetFilename`.

O que investigar: o padrão de ransomware que vimos no Módulo 10 (muitos arquivos modificados/renomeados rapidamente); arquivos executáveis sendo criados em pastas de inicialização automática (`\Startup\`); qualquer criação de arquivo por um processo já suspeito por outro motivo (Event ID 1).

Lógica de detecção (exemplo):

```
SE TargetFilename contém "\Startup\"
E TargetFilename termina com ".exe" ou ".lnk"
ENTÃO alertar (Severidade: Alta) — possível persistência via pasta
de inicialização
```

Event ID 12/13/14 — Registry (Create/Delete, Value Set, Rename)

O que é: modificações no Registry — criação/exclusão de chave (12), definição de valor (13), renomeação (14).

Campos principais: `Image` (processo que modificou), `TargetObject` (caminho completo da chave/valor), `Details` (novo valor, no Event ID 13).

O que investigar: exatamente as Run keys do Módulo 02, Aula 1 — este é o evento que **captura em tempo real** a criação de persistência via Registry.

Lógica de detecção (exemplo):

```
SE TargetObject contém "CurrentVersion\Run"
ENTÃO alertar (Severidade: Alta) — toda escrita nessa chave merece
verificação, mesmo que a maioria
seja legítima (software instalando
normalmente)
```

Event ID 22 — DNS Query

O que é: um processo fez uma consulta DNS — lembrando do Módulo 03, Aula 4, sobre DNS ser frequentemente o **primeiro sinal** de atividade maliciosa, antes mesmo da conexão de rede (Event ID 3) acontecer.

Campos principais: `Image` (processo que consultou), `QueryName` (o domínio consultado), `QueryResults` (os IPs retornados).

O que investigar: domínios com nome estranho/aleatório (padrão DGA, Módulo 03 Aula 4), consultas vindas de um processo que não deveria fazer requisições de rede, alto volume de consultas NXDOMAIN seguidas.

Lógica de detecção (exemplo):

```
SE QueryName tem entropia alta (nome "aleatório", muitas consoantes  
sem padrão de linguagem natural)  
ENTÃO marcar para revisão manual – possível DGA
```

Conectando os seis eventos num incidente único

Revisitando o cenário que já usamos (Word malicioso → PowerShell → persistência), veja como cada Event ID captura uma parte da história:

```
Event ID 1 → winword.exe cria powershell.exe (com -enc)  
Event ID 22 → powershell.exe consulta um domínio malicioso  
Event ID 3 → powershell.exe conecta no IP resolvido, porta 443  
Event ID 11 → powershell.exe cria svhost.exe em %APPDATA%  
Event ID 13 → powershell.exe escreve a Run key apontando pro svhost.exe  
Event ID 1 → (mais tarde, no próximo boot) svhost.exe é executado  
automaticamente pela Run key
```

Nenhum evento sozinho conta a história completa — mas **juntos**, em ordem cronológica, eles reconstroem exatamente o ataque, do início ao fim. Isso é o que Threat Hunting (Módulo 14) e Incident Response (Módulo 15) fazem na prática: juntar esses pontos.

Exercício prático

Se você tem o Sysmon instalado (Aula 1), gere você mesmo um evento de cada tipo, de forma inofensiva, e observe no Event Viewer:

```
notepad.exe # Event ID 1  
Test-NetConnection google.com -Port 443 # Event ID 3 (e possivelmente 22)  
New-Item -Path "$env:TEMP\teste_sysmon.txt" -ItemType File # Event ID 11
```

Depois:

```
Get-WinEvent -LogName "Microsoft-Windows-Sysmon/Operational" -MaxEvents 20 |  
Where-Object { $_.Id -in 1,3,11,22 } |  
Select-Object TimeCreated, Id, Message | Format-List
```

Recapitulando o Módulo 11

- Event ID 1 (processo) é o mais central; 3 (rede) e 22 (DNS) mostram comunicação; 7 (DLL) e 11 (arquivo) mostram carga/impacto local; 12-14 (Registry) capturam persistência em tempo real.
- Cada evento sozinho é uma pista; a reconstrução completa de um incidente vem da sequência cronológica de vários eventos juntos.
- Configuração pública testada (Aula 1) + entendimento de cada Event ID (esta aula) é a base para qualquer detecção formal que construiremos no Módulo 21.

Módulo 11 concluído. 🎉

Próximo módulo

Módulo 12 — Threat Intelligence: IOC, IOA, TTP, e como enriquecer tudo que vimos até aqui (IPs, domínios, hashes) com contexto sobre quem está por trás de um ataque.

Fontes recomendadas

- **Microsoft/Sysinternals — "Sysmon Event ID Reference":** documentação oficial completa de todos os Event IDs, incluindo os não cobertos nesta aula. <https://learn.microsoft.com/sysinternals/downloads/sysmon>
- **MITRE ATT&CK — T1055 (Process Injection) e T1574 (Hijack Execution Flow):** técnicas relacionadas ao Event ID 7 (DLL sideloading/ injection). <https://attack.mitre.org/techniques/T1055/>